

Enterprise AI Model Strategy

Evaluation and vendor selection across six sectors

Research date 25 September 2026

Organizations should select models by workload, required controls, and cost per accepted outcome. A single enterprise model standard is rarely sufficient for reasoning, document processing, forecasting, scientific prediction, and physical control. A small approved portfolio, governed through common evaluation and operating controls, is the recommended starting architecture.

This report covers proprietary services, open weight deployment, adaptation of existing models, and custom development. It focuses on foundation models while retaining conventional machine learning and deterministic software as alternatives. Regulatory examples emphasize the United States and European Union. Recommendations and illustrative economics are analytical synthesis; numbered references identify supporting primary evidence. Product documentation describes available controls, not proof that a particular customer deployment satisfies them.

The principal decisions are:

- Buy managed capability when demand is uncertain, general reasoning matters, and the exact service passes data and operational requirements.
- Operate open weights when local execution, release control, customization, or measured economics justify owning the serving lifecycle.
- Adapt an existing model when persistent task errors can be corrected with lawful, representative examples and the improvement survives independent evaluation.
- Build specialist models where proprietary data and a specific prediction objective create advantage. Treat training a general foundation model from scratch as a separate investment with substantially greater uncertainty.
- Keep business policy, identity, source data permissions, action authorization, evaluation assets, and outcome telemetry under enterprise control.

Four findings materially affect selection. Open weights are not necessarily open source under the Open Source Initiative definition. Regional storage is not the same as regional processing. Zero data retention depends on the particular model and feature. Access to weights does not establish interpretability, clinical safety, airworthiness, or legal permission to deploy. [1, 7–14]

No universal model ranking is defensible without a workload and deployment specification. Public evaluations help form a shortlist. The award decision should follow an enterprise test using real task distributions, explicit risk limits, production service objectives, and complete costs.

The report proceeds from model choices and selection gates to evaluation, economics, architecture, vendor diligence, six sector applications, and an implementation sequence. The final source register distinguishes current rules, guidance, research, and vendor documentation.

1 Separate the model decisions

The categories in a procurement discussion often overlap. A proprietary model can be customized through a managed service. An open weight model can be consumed through a commercial API. An internally tuned model can remain dependent on another organization's license, base model, and runtime.

Decision	Alternatives	What changes
Model access	Proprietary service or licensed downloadable weights	Access to parameters and rights to operate or modify them
Deployment	Shared API, dedicated service, customer cloud, local data center, edge	Data path, infrastructure responsibility, capacity and isolation
Adaptation	Prompting, retrieval, tools, fine tuning, distillation, continued pretraining	How knowledge, behavior and efficiency are improved
Development	Existing foundation model, custom task model, foundation model from scratch	Research investment, data requirements and lifecycle ownership

The proprietary route compared here means closed weight models accessed through licensed services or software. Open weight models can also remain proprietary under their licenses. Neither category determines whether a provider may train on enterprise data or whether only a public endpoint is available. Those are separate contractual and technical questions.

Open weights means parameters are available under specified terms. The license may restrict use, distribution, branding, or particular licensees. OSI's definition additionally requires relevant code, sufficient training data information, and freedoms to use, study, modify, and share. A permissive weight license alone does not prove that every requirement is met. [1]

Custom development has several distinct investment levels. Retrieval augmented generation, or RAG, supplies external evidence without changing weights. Fine tuning changes learned behavior. Distillation transfers task behavior from a teacher to a student. Continued pretraining extends an existing representation. Training from scratch creates new parameters and a complete development obligation. LoRA is an adaptation method that learns smaller parameter updates while freezing the base weights; it does not remove upstream dependencies. [44]

Use the failure mechanism to select the intervention. Missing current facts point to retrieval or transactional tools. Repeated schema and task behavior errors may justify fine tuning. A latency or unit cost problem may justify distillation or a smaller model. A genuinely unmet modality or scientific objective may justify a custom architecture. More training will not repair incorrect source permissions, stale policies, or a broken business process.

Keep the baseline honest. Rules, search, optimization, and conventional classifiers can be more appropriate than a generative model for exact calculations, ranking, forecasting, and bounded decisions.

2 Compare the operating choices

These are conditional tradeoffs, not claims that one model class is always cheaper, safer, or more capable.

Route	Strongest fit	Principal tradeoff
Proprietary managed service	Broad reasoning, variable demand, rapid implementation	Low initial infrastructure burden; continuing usage charges, change exposure and provider dependency
Managed open weights	Portable model choice with limited internal serving capacity	Hosting reduces operations work but adds provider dependency and service specific terms
Self hosted open weights	Local execution, controlled releases, sustained demand, specialized serving	Greater runtime control; enterprise owns capacity, security, availability and upgrades
Adapted existing model	Stable tasks with measurable, recurring failure patterns	Potential quality or cost improvement; labeling, evaluation and regression obligations
Custom task model	Distinct prediction target and proprietary training signal	Strong task fit; narrower reuse and ongoing data maintenance
Foundation model from scratch	Material unmet capability plus durable data and scale advantage	Maximum development control; research risk, capital commitment and recurring refresh cost

Performance must be evaluated at the intended operating point. A broad model may produce better results on unfamiliar tasks yet require more latency and tokens. A smaller specialized model may outperform it on a narrow workflow but fail outside that distribution. Neither parameter count nor weight availability predicts the winning configuration.

Security responsibility moves with the route. Managed providers operate much of the infrastructure, but the enterprise still controls access, retrieval permissions, downstream actions, and application logs. Internal operation removes some external data paths while adding responsibility for model artifacts, dependencies, containers, hardware, incident response, and recovery. NIST's AI secure development profile extends software development practice to model development and supporting assets. [3]

Scalability has two components: capacity and repeatability. Capacity is the number of acceptable outcomes delivered within service limits. Repeatability is maintaining that performance across business units, languages, jurisdictions, devices, and model changes. A service with high aggregate throughput can still fail the enterprise through tail latency, regional quotas, weak tenant isolation, or inconsistent behavior.

The recommended default is to establish a managed capability baseline, compare an appropriate open weight candidate, and add specialization where measured benefit warrants the operating cost. A backup is valuable only after testing its behavior, data constraints, and recovery path.

Before funding foundation model training, require a demonstrated gap after retrieval and adaptation, lawful differentiated data, a team able to repeat training and evaluation, a funded refresh and serving plan, and positive economics under conservative demand. Budget failed experiments and revalidation. For a specialist model, apply the same logic at the smaller task scope.

3 Use gates before a weighted score

First define the decision unit: one workflow, specified users, data classes, jurisdictions, permitted actions, and service objectives. Record the current cost, throughput, error rate, and human effort. The procurement object is the complete configuration: model version, host, endpoint, region, features, retrieval, tools, and contract.

Gate	Required evidence	Failure disposition
Permitted use and rights	Exact license, data and derivative rights, teacher output training rights, use restrictions	Exclude the configuration
Data and sovereignty	Complete processing and retention map, authorized access, approved jurisdictions	Exclude or redesign the data path
Quality and safety	Private test results meeting task and harm thresholds	Restrict scope, remediate, or reject
Security and action control	Isolation tests, least privilege, protected secrets, enforced authorization	Block production until corrected
Operational fitness	Peak load, outage recovery, version control, support and capacity evidence	Constrain rollout or reject
Accountability	Named owner, evaluation records, change process, incident and exit responsibilities	Do not launch without ownership

Missing evidence is an unresolved gate, not a neutral score. Strong average performance cannot compensate for an impermissible data transfer or a materially unsafe action.

After gates pass, compare candidates using a weighted score and a cost sensitivity analysis. Select a primary model for each workload class rather than maximizing the number of approved models. Keep a validated fallback where continuity needs justify its cost. An API adapter can reduce integration effort but does not make models behaviorally interchangeable.

Define acceptance before testing. For extraction, specify field accuracy and critical omission limits. For support, distinguish a correct resolution from justified escalation; escalation alone may not complete the business task. For an agent, validate the final business state, authorization, and side effects. For advice, test factual support, usefulness, uncertainty, and review requirements. Do not define success as merely producing fluent text.

Use stronger assurance as consequence increases. Drafting a reversible internal note, proposing a treatment, denying a benefit, and changing a flight function are different decisions. Human review is effective only if reviewers have sufficient evidence, time, competence, and authority to detect and correct failures.

The NIST AI Risk Management Framework is voluntary and useful for organizing governance; it is not a certification or substitute for applicable sector obligations. [2]

4 Vendor evaluation scorecard

The weights below are a proposed starting point, totaling 100. Set them before the test. Mandatory controls remain gates; the score measures relative merit among eligible candidates.

Criterion	Weight	Evidence to request
Task quality and reliability	25	Private holdout results, critical errors, abstention, subgroup performance, repeated reliability
Complete cost	20	Cost per accepted task at low, base and peak demand; review, retry and migration costs
Security and privacy	15	Isolation, access controls, key handling, security tests, incident process, data use terms
Sovereignty and control	10	Storage and processing locations, support access, subprocessors, keys, offline dependencies
Capacity and resilience	10	Load curves, quotas, committed capacity, failover tests, recovery objectives
Integration and customization	8	Tool and schema behavior, adaptation support, observability, accessible evaluation interfaces
Portability and change control	7	Version support, deprecation notice, export rights, replacement test and exit cost
Supplier viability and support	5	Relevant references, staffing, financial continuity evidence, support escalation and remedies

Score each criterion from 0 to 5. A zero means absent or unacceptable evidence; 1 means an unverified assertion; 2 means partial evidence or a narrow demonstration; 3 means the stated requirement was demonstrated; 4 means it was exceeded on representative tests; 5 means it was exceeded with independent evidence and durable contractual support where relevant. Weighted score equals the sum of each weight multiplied by its score divided by five.

Record confidence separately as high, medium, or low. A polished demonstration with low evidence confidence should not outrank a validated result. Avoid decimal precision that the evidence cannot support.

Sector adjustments should reflect the specific workflow. For a critical government or aerospace workload, move weight toward sovereignty, assurance, and resilience. For retail content processing at scale, cost and throughput may dominate after brand, privacy, and quality gates pass. For clinical or credit decisions, increase quality and governance emphasis while retaining hard consequence thresholds.

Evaluate three counterparties where applicable: the model developer, the hosting operator, and the application or implementation supplier. Assign responsibility for each incident and change. A hosting certification does not validate the model's business behavior; an application vendor's promise does not override the upstream model's terms.

Preserve the completed scorecard, evidence links, dissenting assessments, assumptions, and decision owner as the procurement record.

5 Run a production relevant evaluation

Public benchmarks provide comparison signals. They cannot establish performance on private documents, local language, unusual exceptions, or an enterprise's tool environment. HELM supports evaluating multiple dimensions and making coverage gaps explicit. Use that principle without treating an old leaderboard as a current procurement ranking. [4]

Build three datasets: a development set for iteration, a locked holdout for selection, and a challenge set for rare but consequential failures. Use lawful examples representing task frequency, document quality, languages, user groups, long contexts, conflicting evidence, and missing information. Split by time, customer, or source where needed to avoid near duplicate leakage.

Run both a controlled model comparison and a production configuration comparison. The first holds prompts, data access, and budgets consistent. The second permits model specific optimization within the same quality, cost, and latency limits. This distinguishes model capability from integration quality.

Dimension	Measure
Outcome quality	First attempt correctness, final acceptance, omissions, reversals and human correction time
Evidence quality	Source validity, claim support, retrieval coverage, freshness and permission compliance
Agent behavior	Authorized actions, final state, duplicate effects, stopping behavior and recovery
Robustness	Prompt injection, conflicting instructions, unavailable tools, malformed input and distribution shift
Performance	p50, p95 and p99 completion latency, concurrency, time to first token and error rate
Economics	Total cost per accepted outcome, including retries, tool calls, review and failures

Repeat stochastic tasks and report uncertainty. Success in at least one of several attempts is not equivalent to reliable success on a single production attempt. Anthropic's evaluation guidance distinguishes these measures and emphasizes examining outcomes and trajectories. [20]

Use deterministic checks for schemas, calculations, permissions, and final state wherever possible. Calibrate model judges against blinded expert labels. Track false acceptance and disagreement; a judge sharing the generator's blind spots can conceal errors. Self reported confidence and token probabilities should not be treated as calibrated correctness probabilities without validation.

Choose sample size from the failure threshold and desired precision. Under an independent Bernoulli approximation, zero failures in 300 trials still permits a roughly 1 percent upper failure bound at 95 percent confidence. Rare safety events require additional hazard analysis, adversarial testing, and monitoring; a small clean sample is not proof of safety.

Release only when task quality, critical risk, service performance, and cost all pass their predetermined thresholds.

6 Model the complete economics

Use one time horizon and the same offered workload distribution. Cost per accepted task is total attributable cost divided by accepted completed tasks. Include development, data, training, inference, retrieval, tools, evaluation, review, rework, operations, security, and transition. Report offered tasks, autonomous completions, escalations, unresolved cases, and final accepted completions separately. Include human completion costs after escalation so that rejecting hard cases cannot manufacture an apparent advantage. Acceptance includes quality and service requirements; residual risk remains separate.

Cost component	Managed service	Internally operated model
Consumption	Input, output, caching, reasoning or media charges, tools and retries	Compute time, storage, networking and serving overhead
Fixed commitments	Reserved capacity, minimum spend, platform fees	Capacity reservation or depreciation, support and operating staff
Quality	Human review, escalation, correction and failed workflow cost	The same costs, including adaptation regressions
Lifecycle	Integration, evaluation, provider upgrades, migration	Training, artifacts, patches, requalification, fleet upgrades and recovery

For API estimates, use the actual token distribution and billing rules, not one average prompt. Count every model call in an agent trajectory. For internal hosting, include idle capacity, redundancy and regional fragmentation. On owned hardware, avoid double counting the purchase price and depreciation over the same period. Shared platform costs should be allocated consistently; show marginal and fully allocated costs separately.

Illustrative break even, not vendor pricing: assume equal acceptance quality and latency. A managed service costs \$0.012 per accepted task. Internal operation costs \$0.004 per accepted task plus \$20,000 additional monthly fixed cost. The break even volume is \$20,000 divided by \$0.008, or 2.5 million accepted tasks per month.

Accepted tasks per month	Managed service	Internal operation
1 million	\$12,000	\$24,000
2.5 million	\$30,000	\$30,000
5 million	\$60,000	\$40,000

This example holds only within the capacity supported by the assumed fixed cost. Additional replicas create cost steps. An extra \$0.01 of review per internally processed task eliminates the variable cost advantage. Discounts, lower demand, hardware scarcity, or a stronger managed model can reverse the result.

Sensitivity analysis should vary demand, peak concurrency, acceptance rate, context length, output length, retry count, review minutes, staffing, capacity commitments, and refresh frequency. Compare the incremental benefit of customization with its incremental lifecycle cost.

Measure realized value through released capacity, reduced expense, improved throughput, contribution margin, or avoided loss. Hours nominally saved are not automatically cash savings. Use controlled comparisons where possible to separate model effects from workflow redesign and changes in demand.

7 Security and sovereignty requirements

Sovereignty is a set of enforceable controls. Evaluate data location, processing location, legal jurisdiction, authorized operators, encryption keys, update control, and continuity without the provider. A regional endpoint may satisfy some requirements without satisfying all of them.

Map prompts, uploaded files, retrieved passages, embeddings, caches, outputs, training data, adapters, traces, safety monitoring records, backups, and support exports. Identify the operator, location, retention, deletion procedure, and legal access boundary for each. Apply the same analysis to external tools and evaluation services.

Question	Required proof
Where is data processed	Exact endpoint and model commitments, routing configuration and failover destinations
Who can access it	Role definitions, support access process, subprocessors and administrative controls
How is it retained	Feature level retention schedule, legal and abuse exceptions, deletion and backup behavior
Who controls keys	Key scope, revocation behavior, recovery procedure and limits during active processing
Can the system operate independently	Offline dependency test, artifact access, license activation, recovery and update paths
Can the enterprise leave	Exportable data and artifacts, contractual rights, replacement test and verified deletion

Provider promises must be read precisely. OpenAI documents endpoint and feature limits on zero data retention and distinguishes storage residency from regional processing. Anthropic documents model and feature eligibility, including covered model retention requirements and explicit exceptions. Neither should be converted into a blanket claim that every enterprise feature retains nothing. [7, 8]

Microsoft distinguishes Global, DataZone, and other deployment types. Google distinguishes global, jurisdictional, and locational processing commitments. AWS distinguishes geographic from global routing. More geographic flexibility can improve capacity access while violating a narrower permitted data boundary. [10–14]

Security testing should cover unauthorized retrieval, prompt injection through documents and tools, secret exposure, cross tenant leakage, poisoned training data, compromised model artifacts, excessive privileges, and uncontrolled output execution. NIST's adversarial machine learning taxonomy provides a useful threat vocabulary. [43]

Treat retrieved content as evidence, not authorization. Enforce access before retrieval and independently at every action boundary. Use scoped credentials, validated parameters, transaction limits, and audit records. A model must not authorize its own proposed action.

Internal hosting reduces selected external dependencies but does not remove supply chain or insider risks. Weight access does not reveal all training data, prove absence of memorization, or create a faithful explanation of a consequential decision. Review contracts for training rights, ownership, indemnity scope and exclusions, audit access, incident notice, changes to terms, and exit assistance.

8 Engineer scalable operations

Select the largest safe workload the system can sustain, rather than its maximum advertised tokens per second. MLCommons Endpoints measures throughput, concurrency, interactivity, and p95 time to first token together. Its end to end RAG benchmark uses tasks per second for question answering because token rate cannot represent the complete pipeline. [5, 6]

Define service objectives at the workflow boundary: accepted tasks per second, p95 and p99 completion latency, availability, and recovery time. Test realistic arrival bursts, document lengths, tool delays, cache misses, cold starts, regional failures, and one capacity unit unavailable. Human review queues are part of capacity planning.

For local serving, memory includes weights, activations, runtime buffers, and attention caches. Conventional transformer KV cache demand grows with active sequences and context length, as well as model architecture and precision. Parameter count alone is insufficient for sizing. vLLM documents parallel deployment choices and cache capacity; its quantization guidance highlights calibration and model specific sensitivity. [18, 19]

Batching, quantization, caching, and speculative decoding can improve cost or throughput, but each changes the operating envelope. Recheck quality after numerical changes. Validate tenant isolation in shared caches. Count longer queues against latency objectives. For mixture of experts models, distinguish active computation from total weight storage and network demands.

Use a policy controlled routing layer with a small approved catalog. Route by data classification, task, region, quality requirement, latency, and budget. Escalate from a smaller model only when the escalation signal has been validated. Never send restricted data to an unapproved fallback during an outage.

Enterprise capability	Responsibility
Data and retrieval	Source permissions, freshness, provenance and deletion
Model registry	Version, license, approved tasks, evaluations, runtime and region
Runtime control	Routing, quotas, action authorization, timeout and spending limits
Evaluation and release	Holdouts, regression tests, canaries, rollback and approval records
Observability	Outcome quality, traces, latency, spend, incidents and review burden

Freeze the deployable configuration, including the prompt, model, adapter, retrieval version, tool schema, and runtime. Promote changes through offline evaluation, shadow use, limited production, and expanded rollout. Set automatic rollback criteria for critical errors, latency, cost, and quality regressions.

Keep a retirement process. Additional models create evaluation, security, support, and integration costs. Retain only those with a demonstrated workload advantage or continuity role. A provider independent interface is useful, but genuine portability requires a successfully rehearsed replacement.

9 Build the vendor shortlist

The following are representative diligence targets, not performance rankings or endorsements. Compare the exact model release and deployment channel available to the enterprise. Availability, commercial terms, and controls can change between evaluation and contracting.

Candidate route	Verified distinction	Procurement implication
OpenAI platform	Retention eligibility and regional processing vary by feature and model [7]	Validate each endpoint, tool, stateful feature and negotiated exception
Anthropic Claude	Retention varies by model and feature; some models require express authorization for ZDR [8]	Check exact model and channel; obtain written eligibility
Microsoft Foundry	Global and DataZone deployment types have different processing boundaries [10]	Specify deployment type in the approved configuration
Google enterprise model platform	Global endpoints do not guarantee processing residency; feature retention varies [11, 12]	Test the selected jurisdictional or locational endpoint and optional features
Amazon Bedrock	Geographic and global routing differ; retention policies can be model specific [13, 14]	Inspect effective model retention settings and destination regions
IBM Granite 4.1	IBM states the release uses Apache 2.0 [15]	Candidate for adaptation and internal operation; validate the exact task and runtime
Mistral 3 releases	Specified Large 3 and Ministral 3 releases use Apache 2.0 [16]	Review release terms rather than assuming one license for the vendor
Meta Llama 4	Community license contains use and distribution conditions [17]	Review acceptable use, attribution and additional license conditions

An enterprise should usually test a small set: a strong managed baseline, a lower cost managed option, a suitable open weight configuration, and a specialist or adapted candidate when relevant. The hosting provider may be evaluated independently from the model developer. Do not assume direct API and cloud marketplace versions have identical features or terms.

Roadmap claims require separate treatment. Anthropic announced Enterprise Frontier Safeguards on 1 September 2026, describing customer controlled monitoring storage and a phased rollout beginning later in the fall. The announcement is evidence of direction, not proof that a specific tenant already has the capability. [9]

For every shortlisted vendor request a dated evidence pack: model and system cards, evaluation access, data flow and retention schedules, security evidence, capacity commitments, release and deprecation policy, commercial schedule, support terms, rights to outputs and adaptations, indemnity terms, and a tested exit path.

Do not reward unsupported roadmap promises as current capability. Revalidate the winning configuration immediately before contract signature and production release.

10 Financial services

Financial services should separate language assistance, statistical decisions, and financial actions. The relevant model portfolio depends on the loss mechanism, required explanation, data sensitivity, and frequency of the task.

Workload	Recommended evaluation route	Principal outcome measures
Research and policy assistance	Managed proprietary or private open weights with permission aware retrieval	Supported claims, freshness, analyst review time
KYC extraction and case preparation	Smaller adapted model or classifier, with escalation	Field accuracy, missed entities, cost per accepted case
Fraud, credit and quantitative risk	Specialist statistical or custom ML models as baselines	Realized loss, calibration, false positives, segment performance
Customer servicing	Approved hosted or private model with bounded tools	Correct resolution, unsupported advice, complaints and rework
Payments and account changes	Model proposal with independent transaction authorization	Unauthorized actions, reconciliation errors and recovery

Use proprietary services when broad capability and variable demand outweigh the cost of usage and external dependency. Use private open weights where controlled releases, narrow data paths, or stable demand create a measured advantage. Custom development is strongest for proprietary fraud, transaction, and behavioral signals. Owning a general language model is not a prerequisite for owning those decision capabilities.

For adverse credit actions, reasons must reflect the actual decision factors. Regulation B requires specific principal reasons, and its commentary ties those reasons to factors considered or scored. A plausible generated explanation is insufficient. Preserve the decision engine's reason record and constrain the language model to faithfully communicate it. [22]

The regulatory baseline has changed. Federal Reserve SR 26-2, issued 17 April 2026, supersedes SR 11-7 and SR 21-8. Its model risk guidance expressly excludes generative and agentic AI from scope while directing institutions to determine appropriate governance for excluded systems. Do not claim that an LLM is directly compliant with this guidance. [21]

Third party governance should cover selection, contract, monitoring, concentration, and exit. Relevant EU institutions must also assess DORA obligations for ICT services; DORA has applied since 17 January 2025. [23, 24]

Require temporal holdouts and evaluate by product, language, document type, and relevant customer segment. Test conflicting records, stale policies, identity errors, and malicious content. For autonomous workflows, enforce transaction limits, separation of duties, replay protection, and reconciliation outside the model.

Scale only when accepted case throughput and loss outcomes improve after review and exception handling are included. Track manual escalation, reversals, reviewer minutes, tail latency, and recovery separately from raw model accuracy. Set acceptance thresholds from financial exposure and customer consequence, not a generic benchmark percentage.

11 Government

Government requires segmentation by mission and information class. Public information, internal work, sensitive citizen data, controlled information, and classified systems cannot share one default deployment policy. National security systems require separate policy analysis from the OMB memoranda cited here.

Workload	Recommended evaluation route	Principal outcome measures
Public service information	Managed model grounded in authoritative public sources	Correct service completion, citations, language quality and accessibility
Internal drafting and policy search	Approved hosted service or private deployment	Permission leakage, correction effort and records integrity
Benefits and licensing support	Controlled extraction and decision support with consequential use review	Erroneous determinations, appeals, bias, processing time
Restricted or disconnected missions	Locally deployable open weights or appropriately licensed proprietary solution	Offline continuity, authorized access, update control and mission performance

Choose a managed service where it passes mission, security, procurement, and data requirements. Choose local execution where disconnection, control, or information restrictions require it. Open weights improve deployment options but do not themselves confer permission to process government information. Check supply chains, remote administration, dependencies, and access to updates.

OMB M-25-21 establishes risk management practices for covered high impact AI uses, including assessment, testing, monitoring, and human oversight. Human involvement does not automatically remove a use from that category. M-25-22 makes evaluation, portability, data and intellectual property rights, and ongoing testing relevant to acquisition. [25, 26]

OMB M-26-04 adds requirements for covered LLM procurement concerning its stated truth seeking and ideological neutrality principles, including documentation and feedback mechanisms. It treats free open source acquisition differently and excludes national security systems. Map the exact procurement to current agency implementation rather than applying a generic checklist. [27]

Verify the cloud service's applicable FedRAMP status and boundary, then obtain the necessary agency system authorization. Treat the integration, data connections, tools, and mission use as enterprise responsibilities. FedRAMP's 2026 consolidated rules are in transition; the published timeline specifies mandatory adoption on 1 January 2027, subject to stated applicability and effective dates. [28, 45]

Maintain auditable source evidence, reasons for consequential decisions, accessible review and appeal processes, and controlled model changes. Test service quality across languages and accessibility needs. Retain public records according to applicable requirements while minimizing unnecessary sensitive content in operational telemetry.

The decisive metrics are correct service completion, backlog age, erroneous determinations, appeal reversals, manual correction effort, and continuity under provider failure. Measure whether the system improves public service outcomes rather than merely increasing document production.

12 Healthcare and life sciences

Select the assurance requirements before selecting the model. Administrative drafting, clinical recommendations, device functions, and scientific evidence each have different failure consequences and validation needs.

Workload	Recommended evaluation route	Principal outcome measures
Administrative and coverage support	Approved proprietary service or private open weights with versioned retrieval	Accepted case cost, rework, review minutes and turnaround
Clinical documentation and support	Locally validated system with traceable evidence and defined clinician responsibility	Clinically material errors, omissions, calibration and subgroup results
Regulated device functions	Supplier or internal route supporting the required evidence and change lifecycle	Intended function performance and hazard derived acceptance
Drug and scientific discovery	Existing scientific models or custom models where proprietary data justify them	Experimental confirmation, prospective replication and cost per validated candidate

Use retrieval for changing clinical references, coverage policies, and member or patient records. Fine tune for persistent terminology or task behavior only after separating model failures from poor source quality. Document assembly and coding assistance should be evaluated separately from clinical or coverage determinations; administrative placement does not eliminate consequential decision risk.

HHS permits cloud processing of ePHI with the necessary business associate agreement and safeguards. A provider holding encrypted ePHI can still be a business associate without possessing the key. HIPAA itself does not impose a blanket United States hosting requirement; geographic risk, other laws, and contractual restrictions still matter. [30]

FDA's final January 2026 clinical decision support guidance addresses the statutory boundary for Non-Device CDS. One criterion is that the professional can independently review the recommendation's basis rather than primarily rely on it. A human approval button alone is insufficient. Require evidence adequate for that review and assess intended use and time sensitivity. [31]

For device functions, weight ownership cannot replace the applicable regulatory assurance process. FDA's January 2025 AI device lifecycle and drug or biologic AI credibility documents remain drafts in the retrieved official publications. The drug draft proposes credibility tied to context of use. FDA and EMA's January 2026 good AI practice principles also emphasize context, data, evaluation, and lifecycle management. [32–34]

Custom scientific models have a stronger case where distinct assay, imaging, sequence, or experimental data support a defined objective. Evaluate on prospective experiments and independent samples, not only retrospective leaderboard tasks. Include failures, reproducibility, and the cost of scientific validation in the business case.

Scale by site, specialty, population, and workflow only after confirming local performance. Monitor clinically important omissions, overrides, subgroup drift, source freshness, and review burden. The relevant unit of value is a safely completed clinical or administrative task, or a scientifically validated result.

13 Technology and telecom

Technology and telecom need separate strategies for software work, operational language tasks, network prediction, and network control. One general model cannot be assumed to optimize all four.

Workload	Recommended evaluation route	Principal outcome measures
Engineering and architecture	Strong managed model baseline; compare private open weights where constraints justify them	Accepted changes, total engineer effort, escaped defects and security findings
Tickets and log classification	Small adapted model or conventional classifier	Category accuracy, abstention, escalation and cost per resolved case
Incident diagnosis	Model grounded in live topology, configuration, telemetry and runbooks	Correct diagnosis, evidence freshness and restoration time
Traffic, capacity and energy prediction	Custom task models using operator telemetry	SLA performance, forecast error and energy per delivered traffic
Network changes	Bounded recommendations with separate validation and control	Failed changes, service disruption and rollback success

For coding, measure the complete engineering workflow. Include understanding, generation, review, tests, integration, and rework. Code volume and self reported speed are weak substitutes for accepted production changes. METR's February 2026 update explicitly identifies selection and timing problems in its newer productivity study; its evidence does not support one universal current productivity percentage. [39]

Source confidentiality may favor approved private deployment, but a larger hosted model can still be preferable when quality materially reduces total engineering effort and the data agreement permits use. Benchmark actual repositories and languages, including security sensitive changes and unfamiliar code. Restrict repository and tool access to the task.

Telecom incident assistants should retrieve the current network state rather than rely on memorized topology. They can propose diagnoses and runbooks, but configuration writes should pass identity checks, schema and semantic validation, capacity constraints, simulation where appropriate, and staged deployment. Preserve deterministic safeguards and a reliable rollback path.

For timing sensitive control, evaluate compact predictors or bounded control policies against the required latency, stability, and operating domain. Conversational model performance is not evidence of control quality. Customization is most defensible where proprietary telemetry provides a distinct signal and closed feedback allows reliable measurement.

Edge placement is justified when latency, connectivity, privacy, or data movement requirements outweigh fragmented capacity and fleet operations. Include device memory, power, thermal behavior, deployment success, and version diversity. Cloud placement gains from shared capacity and elastic demand, but requires credible regional quotas and recovery.

Track engineering outcomes and network outcomes independently. A model that reduces ticket handling time can still increase incidents through incorrect recommendations. Expand autonomy only when the complete action path has a measured safety and performance record.

14 Industrials and aerospace

Separate information assistance from prediction and physical control. Maintenance document search, inspection, predictive maintenance, robotics, and onboard aviation functions require different data, models, and assurance evidence.

Workload	Recommended evaluation route	Principal outcome measures
Engineering and maintenance assistance	Approved proprietary service or private open weights with controlled document retrieval	Verified task completion, source accuracy and repair time
Inspection and condition monitoring	Custom vision, acoustic or time series models	Escaped defects, false rejects, lead time and verified downtime avoidance
Offline plant or field assistance	Compact local models where hardware and connectivity justify them	Tail latency, offline availability and fleet reliability
Safety related control or flight functions	Task specific models with intended function assurance and controlled changes	Hazard based criteria, operating domain coverage and failure behavior

Private open weights can support disconnected operations, controlled technical documentation, and version stability. They also place patching, artifact integrity, serving capacity, and recovery on the operator. A private deployment should be tested with network access removed; hidden telemetry, remote activation, or update dependencies can defeat the intended operating model.

Custom predictive models often have the clearest business case. Plant specific sensor relationships, failure histories, and inspection images can improve detection and maintenance planning. Evaluate across machines, facilities, environmental conditions, and failure modes. Rare failure data require careful uncertainty analysis; synthetic augmentation does not replace evidence from relevant operating conditions.

NIST's OT security guidance recognizes the distinct performance, reliability, and safety needs of operational technology. The architectural implication is to bound AI authority, separate advisory functions from interlocks, and validate every permitted write through an explicit control interface. [35]

The FAA AI safety assurance roadmap and EASA's Level 1 and Level 2 concept paper provide assurance direction, not generic certification of a language model. Procurement should require the evidence and lifecycle support appropriate to the intended function, hazard classification, operating domain, and human role. Neither an enterprise contract nor downloadable weights makes a system airworthy. [36, 37]

Aerospace data sovereignty includes authorized personnel and legal access. ITAR definitions address technical data releases and conditions for encrypted data treatment. Inference commonly requires plaintext in the processing environment; encryption in storage or transit should not be assumed to resolve access authorization. Trace administrators, support personnel, subcontractors, and failover destinations. [38]

Use controlled releases and prohibit silent changes in assured configurations. For edge fleets, include power, memory, hardware lifetime, staged updates, and rollback in total cost. The outcome is repeatable production or mission performance across the operating environment, not merely fast inference on a laboratory device.

15 Consumer and retail

Retail should distinguish customer conversation from the commercial decision systems underneath it. Shopping assistance needs current product and transaction facts; forecasting, ranking, pricing optimization, and fraud need task specific prediction and objective functions.

Workload	Recommended evaluation route	Principal outcome measures
Shopping and service assistance	Existing proprietary or open weight model with live catalog and policy tools	Correct recommendations, net contribution, resolution and latency
Catalog enrichment	Smaller adapted language or vision model, with escalation	Attribute precision, correction cost and throughput
Forecasting, ranking and fraud	Custom task models or specialist services	Stockouts, waste, incremental margin, false declines and loss
Store vision and offline assistance	Local task models or compact language models where justified	Store specific accuracy, privacy, resilience and maintenance cost

Keep prices, inventory, promotions, eligibility, compatibility, and return policies in authoritative services. Retrieve them at decision time and preserve timestamps. Fine tuning is not a reliable mechanism for maintaining rapidly changing commercial facts. Constrain transactions through explicit permissions, validated parameters, and user authorization.

Amazon's technical account of Rufus describes a model trained from scratch combined with retrieval and store APIs. It shows that custom models and retrieval are complementary. It does not establish that another retailer can justify the same investment or obtain the same outcome. [40]

For most retailers, the evaluation should start with existing models and accurate catalog access. Adapt a smaller model when repeated product attribute extraction or brand requirements create stable tasks at scale. Consider broader training only when proprietary behavior and product data produce a demonstrated gain beyond simpler architectures.

Test seasonal peaks, out of stock items, substitutions, ambiguous compatibility, multilingual interactions, unsupported product claims, and malicious seller content. Evaluate the whole order outcome, including returns, cancellations, discounts, fraud, and support contacts. A conversion increase can destroy value if it raises returns or lowers contribution margin.

Data rights diligence should cover loyalty profiles, customer conversations, product media, seller submissions, and employee data. The FTC has specifically warned AI providers to honor privacy and confidentiality commitments. Training use should be explicit, including downstream reuse and deletion responsibilities. [41]

Keep payment credentials out of prompts where feasible and use constrained transaction tokens. PCI SSC's September 2025 AI principles emphasize access limits, validation, oversight, and protection of payment data; these principles do not create a separate AI compliance certification or replace applicable PCI obligations. [42]

Set a quality and margin floor before routing to cheaper models. Measure cost per accepted catalog record, correct service resolution, and incremental contribution after downstream costs. Use customer experience measures alongside economics so that latency reductions do not conceal incorrect or unsafe recommendations.

16 Contract and implementation sequence

The procurement package should make the tested configuration enforceable. Include permitted uses and data classes; exact model, channel and region; retention and training restrictions; service commitments; support and incident duties; change notice; audit evidence; output and adaptation rights; explicit rights to use teacher outputs for training or distillation; indemnity scope; pricing; capacity; termination; export; and deletion. Confirm accountability at each boundary.

For internal models, create the equivalent operating agreement between product, platform, security, data, and validation teams. Internal development does not remove the need for a named service owner, support budget, documented limits, and an exit or retirement plan.

Stage	Work	Exit evidence
Define	Classify workflows, measure baselines, map data and actions, set thresholds	Approved decision charter and acceptance criteria
Screen	Request evidence, apply gates, select a small candidate set	Eligible configurations with unresolved issues recorded
Evaluate	Private quality tests, adversarial tests, load tests and full cost model	Reproducible comparison with uncertainty and sensitivity
Pilot	Approved pilot terms and data permissions, shadow use, bounded production and recovery exercises	Outcome improvement and operational readiness
Scale	Contract, capacity, staged rollout, monitoring and accountable ownership	Sustained service and business performance
Reassess	Review changes, drift, costs, incidents and supplier dependency	Retain, adapt, replace or retire decision

A 90 day initial cycle is a planning assumption, not a release deadline. Days 1–15 can establish scope and data rights; days 16–35 can screen suppliers and construct evaluation sets; days 36–60 can run tests and commercial analysis; days 61–90 can pilot and complete the decision. Regulated validation, procurement, or data readiness can require more time. No date should override a failed gate.

Record one decision memo per workload: chosen configuration, rejected alternatives, benchmark evidence, residual limitations, economics, approval owner, monitoring thresholds, rollback route, and reassessment trigger. Track technical and business measures separately.

Cross sector legal timing matters. The European Commission's current AI Act page reports general applicability from 2 August 2026 and earlier GPAI obligations. Following the July 2026 AI Omnibus, it identifies 2 December 2027 for Annex III high risk rules and 2 August 2028 for high risk systems integrated into regulated products. Apply the relevant role and use case requirements rather than one blanket deadline. [29]

The durable enterprise assets are the evaluation corpus, authorized data access, domain feedback, workflow integration, operating controls, and verified outcome record. Invest in model ownership where it improves one of those capabilities or produces a defensible economic advantage.

Primary source register

All sources were checked on 25 September 2026. Links identify the evidence used. Vendor documentation establishes stated terms or capabilities, not independent performance or compliance. Recommendations, scoring weights, planning durations, and cost examples are proposed analytical tools.

- [1] Open Source Initiative. [Open Source AI Definition 1.0](#). Definition.
- [2] NIST. [AI Risk Management Framework](#). Voluntary framework and Generative AI Profile resources.
- [3] NIST. [Secure Software Development Practices for Generative AI and Dual Use Foundation Models](#). SP 800-218A, 2024.
- [4] Stanford CRFM. [Holistic Evaluation of Language Models](#). Research methodology, November 2022; used for evaluation principles, not current rankings.
- [5] MLCommons. [MLPerf Endpoints](#). Benchmark methodology and performance curves.
- [6] MLCommons. [Introducing the MLPerf End to End RAG Inference Benchmark](#). August 2026; first implementation is an offline benchmark.
- [7] OpenAI. [Data controls in the OpenAI platform](#). Current product documentation.
- [8] Anthropic. [API and data retention](#). Current product documentation; model and feature eligibility.
- [9] Anthropic. [Developing Enterprise Frontier Safeguards with our customers](#). Announcement, 1 September 2026; phased rollout described.
- [10] Microsoft. [Data privacy and security for Foundry Models sold by Azure](#). Current deployment and data handling documentation.
- [11] Google Cloud. [Data residency](#). Current Gemini Enterprise Agent Platform documentation.
- [12] Google Cloud. [Gemini Enterprise Agent Platform and zero data retention](#). Current feature level documentation.
- [13] AWS. [Amazon Bedrock data retention](#). Current model specific retention documentation.
- [14] AWS. [Route model inference requests across AWS Regions](#). Geographic and global inference profiles.
- [15] IBM Research. [Introducing the IBM Granite 4.1 family of models](#). Release announcement, 29 April 2026; Apache 2.0 statement.
- [16] Mistral AI. [Introducing Mistral 3](#). Release announcement, 2 December 2025; specified release licenses.
- [17] Meta. [Llama 4 Community License Agreement](#). Official repository; license effective 5 April 2025.
- [18] vLLM. [Parallelism and Scaling](#). Current serving documentation.
- [19] vLLM. [Quantized KV Cache](#). Current quantization and calibration documentation.
- [20] Anthropic. [Demystifying evals for AI agents](#). Engineering guidance, 9 January 2026.
- [21] Federal Reserve, OCC and FDIC. [Revised Guidance on Model Risk Management](#). SR 26-2 attachment, 17 April 2026; GenAI scope exclusion in footnote 3.
- [22] Consumer Financial Protection Bureau. [Regulation B Section 1002.9 Notifications](#). Current rule and official interpretations.
- [23] OCC. [Third Party Relationships Interagency Guidance on Risk Management](#). Bulletin 2023-17, 6 June 2023.

- [24] EIOPA. [Digital Operational Resilience Act](#). Official DORA applicability summary.
- [25] OMB. [M-25-21 Accelerating Federal Use of AI through Innovation Governance and Public Trust](#). Memorandum, 3 April 2025.
- [26] OMB. [M-25-22 Driving Efficient Acquisition of Artificial Intelligence in Government](#). Memorandum, 3 April 2025.
- [27] OMB. [M-26-04 Increasing Public Trust in Artificial Intelligence Through Unbiased AI Principles](#). Memorandum, 11 December 2025.
- [28] FedRAMP. [Important Dates for the Consolidated Rules for 2026](#). Current transition schedule.
- [29] European Commission. [AI Act](#). Official application timeline and July 2026 AI Omnibus changes.
- [30] HHS. [Guidance on HIPAA and Cloud Computing](#). Official guidance; BAA and overseas processing questions.
- [31] FDA. [Clinical Decision Support Software](#). Final guidance, January 2026.
- [32] FDA. [AI Enabled Device Software Functions Lifecycle Management and Marketing Submission Recommendations](#). Draft, January 2025; not for implementation.
- [33] FDA. [Considerations for Use of AI to Support Regulatory Decision Making for Drug and Biological Products](#). Draft, January 2025; not for implementation.
- [34] FDA and EMA. [Guiding Principles of Good AI Practice in Drug Development](#). Joint principles, January 2026.
- [35] NIST. [Guide to Operational Technology Security](#). SP 800-82 Rev. 3, final September 2023.
- [36] FAA. [Roadmap for Artificial Intelligence Safety Assurance](#). Version I, July 2024; assurance roadmap.
- [37] EASA. [Artificial Intelligence Concept Paper Issue 2](#). March 2024; Level 1 and Level 2 application guidance.
- [38] eCFR. [22 CFR Part 120 Purpose and Definitions](#). Current ITAR definitions; particularly sections 120.50, 120.54 and 120.56.
- [39] METR. [We are Changing our Developer Productivity Experiment Design](#). Methodology update, 24 February 2026.
- [40] Amazon Science. [The technology behind the shopping assistant Rufus](#). Technical architecture account, 4 October 2024; not independent ROI evidence.
- [41] FTC. [AI Companies Uphold Your Privacy and Confidentiality Commitments](#). Agency guidance, 9 January 2024.
- [42] PCI Security Standards Council. [AI Principles Securing the Use of AI in Payment Environments](#). Guidance, 11 September 2025.
- [43] NIST. [Adversarial Machine Learning A Taxonomy and Terminology of Attacks and Mitigations](#). AI 100-2 E2025, final March 2025.
- [44] Hu and colleagues. [LoRA Low Rank Adaptation of Large Language Models](#). Primary research, 2021.
- [45] FedRAMP. [Agency Responsibilities](#). Consolidated Rules for 2026; certification, integration and agency authorization responsibilities.